Structured deployment and domain approval runbook

Status: proposed; nothing deployed or approved. Evidence snapshot is historical. Named signers and live targets unresolved.

Ownership

Each domain needs named accountable owner, implementer, acceptance authority and backup. Role suggestions in domain_audit.csv are not appointments. Professional/customer acceptance cannot be substituted by generated templates. Private approvals stay in controlled evidence storage.

Gate sequence

1. Scope: reconcile all 16 domains to granular capabilities; preserve broader institutional ambitions.
2. Baseline: pin exact candidate and actual hosting/API/functions/workers/DB/storage targets.
3. Evidence: bind every check to fixture version, runner, run ID, logs, reviewer, expiry and scope.
4. Implement: canonical durable data, least privilege, source authority, audit, retries and compensation.
5. Verify: functional/negative/concurrency/offline/AT/security/recovery/domain cases.
6. Deploy dark: additive migration rehearsal; N-1 compatibility; flags off; target smoke.
7. Accept: applicable professional/commercial/customer paper and UAT; accepted N/A rationale if valid.
8. Activate: exact tenant/cohort/operation, staffed support, alerts, measured kill/restore.
9. Observe: required pilot/dual-run window, complete outcome denominators and authority acceptance.

Candidate manifest

SHA; deployment; build/config digest; schema fingerprint; migration checksums; functions/workers; object backup version; policy and flag versions; target/tenant/cohort/operations; approvers; validity; known-good predecessor; compatibility evidence. Never include secret values.

Stop conditions

Stop affected operations for leaks, unauthorized official/financial writes, identity disclosure, corruption, missing approval/coverage, failed reconciliation or breached accepted thresholds. Blank numerical thresholds block activation; no fabricated SLA/RTO/RPO.

Rollback

Declare scope -> server kill -> verify direct API/worker denial -> pause/checkpoint producers/consumers -> quarantine uncertain in-flight outcomes -> scoped policy off/cache invalidation -> independently restore compatible page/API/functions/workers -> reconcile external source outcomes -> approved forward schema repair or isolated recovery -> restore matching file bytes and access state -> reconcile post-backup writes/revocations -> retest -> fresh acceptance -> bounded reactivation.
Keep refunds/cancellations available only through separately authorized remediation. Never replay irreversible commands blindly. Do not delete queues/receipts or wipe drafts. App rollback is not database/external-record/object restore.

Host caveats

Retrieved ROLLBACK.md describes GitHub Pages and separate functions; canonical host must be verified before using Vercel controls. Inspect Supabase Branching and migration ledger because automation outside repo workflows may apply schema. Build-time flags require rebuild/redeploy; server runtime policies must remain effective on prior client versions. Supabase DB backups do not include Storage object bytes. Restore can reintroduce old grants; current revocations must be reconciled.

Closure evidence

Exact accepted artifact IDs; all required executed test IDs; actual-target manifest; current approvals; named primary/backup and acknowledgement drill; kill/restore/rollback/privacy/offboarding records; completed dual-run/outcome gates. Decision stays HOLD while evidence missing/stale/withdrawn/mismatched.